ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Innotech Omni Vaisala Interface OMWEB02 (BEMS controller / BACnet router-BBMD gateway) · Component type: **Embedded Device (EDR) - BEMS controller with NDR (BACnet router/BBMD) features** · Target SL = SL 3

Where to work	**Focus** (Innotech engineering/config software) via front **USB** or Ethernet (Innotech protocol); the front-panel **HMI**; the built-in **HTML5 web server** (browse the controller IP). Config, users, BACnet/Ethernet settings, and firmware are managed in Focus. Backup/Restore via Focus (BACnet DM-BR-B).
Ports / paths	**BACnet/IP UDP 47808** (0xBAC0) incl. **BBMD**/Foreign-Device + NAT; **BACnet MS/TP** on 2x RS-485; **web server HTTP** (HTML5, port 80); Innotech protocol (Focus discovery) over Ethernet/USB. Up to 2 Ethernet + 2 RS-485 channels; each controller needs a **unique IP + BACnet instance**. **No BACnet Network Security** (non-secure device) - BACnet is unauthenticated cleartext.
Notes	EDR (embedded BEMS controller) with NDR features (BACnet Router + BBMD). Model OMWEB02, fw 6.6.d.4. Default login **Innotech / 1111** is valid only on a **blank** controller and Focus refuses to transfer a config while the password is 1111 - confirm it was changed. No secure boot / signed-firmware root of trust is published - those rows route to compensating provenance controls. Segmentation is the primary SL-3 control.
How to read	Each row = native step-by-step (Focus / web / HMI) + command-level external-tool steps (BACnet). **[Manual gap]** marks a spot where the exact Focus path is not publicly documented - confirm against the Innotech manual. Default read-only. Any BACnet write/DoS testing ISOLATED lab only.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the **Innotech Omni** controller configuration/project backup (via the Omni programming tool), the BACnet object list + **BACnet Router** config, the Vaisala-interface point mapping, the user/access settings, firmware rev (per the BACnet PICS), and the controller logs.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	Access to Focus, the web server, and the HMI requires an Innotech **username + password** held in the controller configuration. Confirm the default **Innotech / 1111** (blank-controller only) has been replaced - Focus will not transfer a config while the password is 1111. **[Manual gap]** set/verify users in Focus user setup and the web/HMI login. **Test:** browse to the controller IP / open Focus without valid creds -> access denied (no anonymous config). **Ext. tools:** Web browser to `http://<ip>` (login prompt); `nmap -sU -p 47808 --script bacnet-info <ip>` (device in scope); Focus (attempt connect w/o creds -> refused).	Login required on Focus/web/HMI; default 1111 replaced; no anonymous config path.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.2	Software process / device identification	Confirm a unique device identity: unique **IP address** and **BACnet Device instance** (BACnet Vendor ID 199, model OMWEB02) per the PICS; each Omni on the network has a distinct IP + instance; RS-485 MS/TP has a unique MAC/Max_Master. **Ext. tools:** `bacwi` (BACnet Who-Is -> unique instance) or `nmap -sU -p 47808 --script bacnet-info`; Wireshark filter `bacnet`.	Unique IP + BACnet instance + MS/TP MAC; no reuse across controllers.	
SR/CR 1.3	Account management	The controller uses configuration-held Innotech accounts (not enterprise IdP). Manage them as controlled credentials: named where the firmware supports multiple users, least privilege, no shared logins, defaults removed; custody of the Focus project (which holds the credentials). **[Manual gap]** confirm the user/access-level model in Focus for this firmware (6.6.d.4). **Ext. tools:** Focus user list review; credential-custody record.	Accounts controlled/least-privilege; defaults removed; Focus project protected.	Compensating.
SR/CR 1.4	Identifier management	Confirm unique user IDs (where supported) and a unique device identity (IP, BACnet instance, serial); no reuse across the BACnet internetwork. **Ext. tools:** `bacwi` across the network (no duplicate instances); asset inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Set a strong password (replace 1111) and store it in the credential vault. **[Manual gap]** the Omni password length/complexity capability is firmware-dependent - capture the enforced policy; where the device cannot enforce complexity, record the residual and compensate with segmentation + physical control. **Ext. tools:** Focus/web (confirm non-default password set); policy evidence.	Strong non-default password set; policy captured; residual recorded if weak.	Partial/Compensating.
SR 1.6	Wireless access management	**N/A.** Wired controller (Ethernet + RS-485) with no native wireless interface. **Ext. tools:** Confirm no wireless module; any wireless is upstream network responsibility.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A / limited at the device.** The OMWEB02 supports only non-secure BACnet and an HTTP web server - no device PKI/TLS is documented. Record N/A; provide confidentiality/integrity via segmentation and TLS at the SCADA/front-end layer. **[Manual gap]** confirm whether the installed firmware offers HTTPS; if so, `openssl s_client -connect <ip>:443`. **Ext. tools:** Confirm no configurable device certificate; Wireshark (web = HTTP cleartext).	N/A/limited device PKI; compensating TLS/segmentation upstream.	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the web/HMI/Focus login masks the password during entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The controller has no documented account lockout - record as a residual; mitigate with physical control, segmentation, and monitoring the web/BACnet interface. **[Manual gap]** confirm any lockout capability in the firmware. **Ext. tools:** Confirm no native lockout; IDS/SIEM on the controller segment for repeated web-auth failures.	No native lockout - residual recorded + compensating controls.	Partial/Compensating.
SR/CR 1.12	System use notification	No native logon banner is documented on the controller; enforce the approved use notice on the engineering workstation (GPO) and any SCADA front-end (compensating). **Ext. tools:** EWS GPO / SCADA banner review.	Use notice at EWS/SCADA (compensating at device).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the controller (BACnet/IP + web + Focus) is reachable only from the trusted BMS zone behind a firewall; the web server and Focus ports are not exposed to untrusted networks; remote access via VPN/jump host. This is a primary control for a light-security device. **Test:** from an untrusted VLAN, reach UDP 47808 / the web server -> must fail. **Ext. tools:** `nmap -Pn -sU -p 47808 <ip>` + `nmap -p 80 <ip>` from the untrusted side (expect filtered); firewall/ACL review.	Untrusted-network access denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm least privilege: BACnet **Present_Value writes** (the PICS shows AI/AV/BV etc. are writable) are restricted to authorized controllers; the Innotech password gates config changes; where the firmware has access levels, operate vs configure are separated. **[Manual gap]** confirm the access-level model in Focus. **Test:** from an unauthorized BACnet client, WriteProperty to a point -> should be blocked at the zone (BACnet has no per-write auth). **Ext. tools:** `bacwp` (WriteProperty attempt, ISOLATED); Focus (config change requires password).	Config change requires the Innotech password; BACnet writes constrained by segmentation.	Compensating.
SR/CR 2.2	Wireless use control	**N/A.** No wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the Focus laptop and the front USB port; removable-media policy on the EWS; only authorized Focus projects/firmware loaded; secure the front USB physically. **Ext. tools:** EWS removable-media policy; physical inspection of the front USB.	Portable/engineering media and USB controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; the controller runs the Focus-compiled configuration and the vendor HTML5 web content only (no user script path). **Ext. tools:** Focus (review the configuration); browse the web server read-only (vendor content only).	Only the trusted configuration + vendor web run; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm the web server / Focus session and the HMI return to a login-required state on inactivity. **[Manual gap]** confirm the web/HMI inactivity-timeout capability. **Ext. tools:** Leave web/HMI idle then retry an edit -> login prompt.	Sessions revert to login on inactivity.	Partial.
SR/CR 2.6	Remote session termination	Confirm web/Focus sessions can be ended and idle sessions close; the controller bounds concurrent BACnet/web connections. BACnet **DeviceCommunicationControl (DM-DCC-B)** can enable/disable comms - confirm it is password-protected so it cannot be abused to cut the device off. **Ext. tools:** `bacdcc` (DeviceCommunicationControl, ISOLATED - confirm password required); web session review.	Sessions terminable; DCC password-protected; concurrency bounded.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	The controller/BACnet has limited native audit; capture configuration changes and attribution in **Focus** (project change records) and log BACnet alarms/events (the PICS supports AE-* and Notification Class) to the BMS/SIEM. **[Manual gap]** confirm the on-device event/log capability for this firmware. **Ext. tools:** Focus change log; BACnet event/COV capture to the BMS historian/SIEM.	Config changes recorded in Focus; BACnet events logged; attribution at the tool layer.	Compensating.
SR/CR 2.9	Audit storage capacity	On-device Trend Log / event buffers are finite (BACnet Trend Log objects) - offload to the BMS/SIEM for retention and confirm alerting if collection fails. **Ext. tools:** BMS/SIEM retention; source-silent alert; confirm Trend Log buffer sizing.	Events offloaded/retained; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	The device supports BACnet **Time Synchronization** (DM-TS/DM-UTC/DM-ATS in the PICS) - confirm it syncs to a trusted BMS time source so event/trend timestamps are accurate and correlate. **Ext. tools:** Confirm Time_Synchronization_Recipients / sync source; Wireshark (BACnet TimeSync).	Reliable, synchronized timestamps (BACnet time sync).	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: lock the controller enclosure; secure the front **USB** and the RS-485/Ethernet terminals; guard any reset. **[Manual gap]** if the firmware allows disabling the web server, disable it when unused. Restrict the RS-485 MS/TP wiring runs. **Ext. tools:** Physical inspection (enclosure/USB/terminals); `nmap -p 80 <ip>` (web state).	Enclosure/USB/terminals controlled; web disabled if unused.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	BACnet/IP + MS/TP are **unauthenticated cleartext** (the OMWEB02 is a non-secure BACnet device) and the web server is HTTP - so integrity/confidentiality come from **containment**: keep all BACnet + web + Focus traffic inside a segmented BMS zone; terminate any TLS/front-end at the SCADA layer; no BACnet across a zone boundary except via a controlled router/BBMD. **Test:** confirm BACnet + web stay in-zone (no cleartext crossing the boundary). **Ext. tools:** Wireshark `bacnet || http` (cleartext, in-zone only); firewall rule review.	BACnet/web contained to the segmented zone; no cleartext across boundaries.	Compensating.
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Innotech firmware runs and there is no code-execution path beyond the Focus configuration. **[Manual gap]** no signed-firmware guarantee is published - verify firmware provenance from Innotech and control the update path tightly (2.3/3.10). **Ext. tools:** Focus (firmware version 6.6.d.4+); firmware-file provenance vs Innotech.	Only vendor firmware runs; provenance verified; no code path.	EDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: password changed from 1111, web server state, BACnet instance/BBMD/foreign-device settings, DCC password, and segmentation, against the hardening baseline; compare the Focus project export. **Ext. tools:** Focus (settings vs baseline export); `nmap -sU -p 47808 --script bacnet-info` (state).	Security-relevant settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the Focus configuration, enable change control, and rely on the login + physical/segmentation controls so unauthorized config/firmware change is detected. Compare online-vs-saved config. **Ext. tools:** Focus (save/compare configuration); change-management record.	Config integrity controlled; unauthorized change detected.	Compensating.
SR/CR 3.5	Input validation	Confirm the controller tolerates malformed BACnet/IP frames (BVLC/APDU) and web requests without malfunction. **ISOLATED only:** fuzz BACnet/IP + the web server on a bench unit and watch operation. **Ext. tools:** BACnet fuzzer (`boofuzz` BVLC/APDU) + web fuzz (ISOLATED); Wireshark.	No malfunction on malformed input.	Do NOT fuzz an in-service controller.
SR/CR 3.6	Deterministic output	Verify defined behavior on comm/sensor loss: BACnet points expose **Reliability/Out_of_Service** and priority arrays - confirm the Vaisala-derived points report Bad/last-known and any physical outputs assume a defined safe state on loss of the weather transmitter or the network. **Ext. tools:** Focus / BACnet read (Reliability/Out_of_Service on Vaisala points); simulate sensor/comm loss -> defined status.	Points report Bad/defined status and outputs assume a safe state on loss.	
SR/CR 3.7	Error handling	Confirm graceful diagnostics/reliability handling without info leak; review the device status and reliability flags; a restart (DM-R) is logged. **Ext. tools:** Focus/web (System_Status, Last_Restart_Reason); BACnet read.	Graceful error handling; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No secured (authenticated/encrypted) session is available (non-secure BACnet + HTTP); integrity is provided by containment. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A/limited at device; compensating segmentation recorded.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Protect the Focus change records / BMS historian and restrict who can clear on-device trends/events (login-gated); lock down the SIEM/historian store. **Ext. tools:** Focus/BMS access review; confirm clearing trends requires login.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware via Focus with firmware obtained from Innotech; verify the version/provenance; plan the update in a maintenance window with a rollback to the prior version. **[Manual gap]** no on-device signature verification is published - provenance discipline is the control. **Ext. tools:** Focus (firmware update flow); Innotech provenance/version check.	Controlled updates from a verified source, with rollback.	EDR-specific/Partial.
EDR 3.11	Physical tamper resistance/detection	Keep the controller in a locked/sealed enclosure; control USB/terminals; config changes are recorded in Focus and BACnet restart/reinit are visible as tamper evidence; seal where required. **Ext. tools:** Physical inspection (enclosure/seal); Focus change log; BACnet Last_Restart_Reason.	Enclosure locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A at device.** No signed-boot supplier root of trust is documented. Record the gap; compensate via firmware-provenance discipline (3.10), physical control, and segmentation. **Ext. tools:** Confirm no documented secure-boot/signed-firmware root; provenance process review.	No documented supplier RoT; compensating controls recorded.	Partial/N-A.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.13	Provisioning asset-owner roots of trust	**Partial/N-A at device.** No asset-owner certificate provisioning (BACnet Network Security / NS-KS not supported). Record the gap; asset-owner trust enforced at the BMS/network layer and by segmentation. **Ext. tools:** Confirm NS-SD/NS-ED/NS-KS not enabled (per PICS); segmentation review.	No asset-owner RoT; compensating controls recorded.	Partial/N-A.
EDR 3.14	Integrity of the boot process	**Partial/N-A at device.** No published verified/secure boot. Record the gap; mitigate via controlled firmware provenance (3.10), physical control, and monitoring. **Ext. tools:** Confirm no secure-boot capability; Focus firmware version.	No documented verified boot; compensating controls recorded.	Partial/N-A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, use Focus to clear/overwrite the configuration and credentials (return toward a blank controller) and remove any backup files so config + passwords are not recoverable. **Ext. tools:** Focus (clear/overwrite configuration; remove credentials); confirm backups purged.	Config and credentials purged on decommission.	
SR/CR 4.3	Use of cryptography	**N/A / limited.** No native crypto (non-secure BACnet + HTTP). Disable the web server if unused and rely on TLS at the SCADA/front-end layer and segmentation. **Ext. tools:** Confirm no device crypto; disable web if unused (2.13/7.6).	N/A/limited; compensating TLS/segmentation upstream.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	This is the primary control. Confirm the controller sits in a segmented BMS zone behind a firewall; because it is a **BACnet Router + BBMD**, tightly control what it bridges: restrict **BBMD Foreign-Device registration** to known devices, review the **Broadcast Distribution Table**, and permit only UDP 47808 to/from authorized peers; no flat convergence with IT. **Test:** attempt a rogue Foreign-Device registration -> rejected/limited. **Ext. tools:** `nmap -sU -p 47808 <ip>` per zone; Wireshark `bvlc` (BDT/FD registrations); firewall rule review.	Controller in a segmented zone; BBMD/router scope restricted; only required BACnet crosses the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose controller/gateway with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services on the device.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose device; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm device status, BACnet alarms/events, and Trend Logs are readable/exportable (Focus / web / BACnet) and forwarded to the BMS/SIEM; a passive OT IDS on the BMS segment gives BACnet visibility. **Ext. tools:** Focus/web export; BACnet event/COV to the BMS historian; passive OT IDS (BACnet-aware).	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm the controller tolerates BACnet broadcast storms / scan floods without losing measurement/routing; the BBMD and 47808 exposure are the main DoS surface - the cell firewall should rate-limit. Monitor while testing. **Ext. tools:** ISOLATED bench: BACnet broadcast storm / `hping3 --flood --udp -p 47808`; watch device status.	Measurement/routing continues under load; resources bounded.	
SR/CR 7.2	Resource management	Confirm bounded resources (Max_Master/Max_Info_Frames on MS/TP; connection limits) so a single service cannot starve the controller. **Ext. tools:** Focus/BACnet (Max_Master/Max_Info_Frames); bench load test.	Resources bounded; no exhaustion-based loss of service.	
SR/CR 7.3	Control system backup	Confirm the Focus configuration is backed up (versioned, offline) and BACnet **Backup/Restore (DM-BR-B)** is available; test a restore to a spare controller for a known-good rebuild. **Ext. tools:** Focus backup repository; restore test (spare controller / DM-BR).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency power	**N/A.** Backup power is a facility/UPS concern; confirm the controller retains its configuration + credentials across a power cycle. **Ext. tools:** Power-cycle test -> config + password + settings retained.	N/A - device retains state across power transfer.	N/A
SR/CR 7.6	Network & security configuration settings	Harden: change the default password, disable the web server if unused, disable unused Ethernet/RS-485 channels and unused protocols (LonTalk/PTP/modem if not used), restrict BBMD/foreign-device, and set BACnet time sync + DCC password. **[Manual gap]** confirm the exact enable/disable toggles in Focus for web/channels. **Ext. tools:** Focus (channel/protocol/web config); `nmap -sU -p 47808 <ip>` + `nmap -p 80 <ip>` (only required reachable).	Least functionality; unused channels/protocols/services disabled.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the controller (model OMWEB02, firmware 6.6.d.4, BACnet instance/Vendor ID 199, channels) is inventoried so vulnerabilities track against Innotech advisories / BACnet-relevant CISA advisories. **Ext. tools:** `nmap -sU -p 47808 --script bacnet-info` (model/fw/vendor); Focus inventory.	Accurate device/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Focus (Innotech config software)	Native config/user/firmware review (all FRs)	Connect via front USB or Ethernet; review users/password (confirm 1111 replaced), BACnet/Ethernet settings, channels, and firmware; back up + compare the configuration as the baseline. [Manual gap] exact menu paths per the Innotech Omni Installation Instructions.	Read/authorized project copy.
Web server (browser)	Remote monitoring & login (1.1, 2.5, 2.13)	Browse http://<ip> (HTML5 dashboard); confirm login required; disable it if unused (firmware permitting).	Read-only; authorized.
Front-panel HMI	Local access review (1.1, 2.5)	Confirm HMI login/lock and settings at the panel.	Physical; authorized.
nmap	BACnet/web exposure & inventory (1.1, 1.13, 5.x, 7.6, 7.8)	`nmap -sU -p 47808 --script bacnet-info <ip>` (vendor/instance/model/fw); `nmap -p 80 <ip>`; scan per zone for segmentation.	Read-only; authorized.
BACnet explorer (YABE / BAC0 / bacnet-stack)	BACnet enumeration & controls (1.2, 2.1, 2.6, 5.x)	`bacwi` (Who-Is), `bacrp` (ReadProperty), `bacwp`/`bacdcc` (Write/DeviceCommunicationControl - ISOLATED); confirm DCC password + BBMD/BDT scope.	Read-only on prod; writes ISOLATED.
Wireshark / tcpdump	Comms integrity & BBMD (1.2, 3.1, 5.x)	Filter `bacnet || bvlc || http`; confirm cleartext BACnet/web stay in-zone; inspect BDT/foreign-device registrations and time sync.	Passive; SPAN/tap only.
BACnet fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` BVLC/APDU + web fuzz on a bench unit; `hping3 --flood --udp -p 47808` storm; watch device status.	ISOLATED bench; never in-service.
Innotech advisories / support	Vuln tracking & manual gaps (3.10, 7.8; [Manual gap] rows)	Track Innotech firmware/advisories; obtain the Omni Installation Instructions + Focus help to confirm the [Manual gap] navigation.	Reference / vendor portal.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.